

TP noté n° 2 — Recherche dirigée

Le modèle de sécurité Windows

20 questions à choix multiple · 4 questions ouvertes · rendu en fin de séance

Pourquoi ce format

Le durcissement pratique de Windows demandait une machine virtuelle que le calendrier ne permet plus d'installer sereinement.

Ce qui est évalué ne change pas : **votre capacité à trouver, comprendre, et justifier.**

- ❏ Une bonne réponse trouvée sans comprendre ne vaut rien ici. C'est le sens du mot « dirigée ».

Comment répondre — la règle des trois éléments

Pour **chaque** question à choix multiple, votre rendu comporte trois choses :

1 La lettre de la réponse

2 Deux à quatre lignes de justification

Pourquoi celle-là, et pourquoi pas les autres.

3 Une source vérifiable

Une URL de documentation, ou une commande et sa sortie sur votre machine.

La règle qui compte

Une lettre juste sans justification correcte ne rapporte aucun point.

C'est délibéré. Deviner rapporte zéro, et recopier une réponse d'un outil génératif sans la comprendre se voit immédiatement à la justification.

✅ Inversement : une lettre fausse avec un raisonnement solide et une source honnête rapporte des points partiels.

Barème — 20 points

Épreuve	Points
20 questions à choix multiple, 0,6 pt chacune	12
4 questions ouvertes de synthèse, 2 pts chacune	8

Même structure que le TP n° 1 : un bloc mesurable, un bloc de raisonnement.

 Malus de 2 points par jour de retard entamé.

Sources et outils

Autorisés et encouragés

La documentation Microsoft Learn, les guides de l'ANSSI, les CIS Benchmarks, MITRE ATT&CK, et votre propre machine Windows.

Autorisés et à déclarer en annexe

Les outils d'IA générative. Ce qui est noté est votre compréhension, et une soutenance peut la vérifier.

Interdit

Rendre une justification dont vous ne pourriez pas défendre chaque phrase à l'oral.

 Toute source citée doit être **datée** et **vérifiable**. Une réponse sans source ne compte pas.

Jeton, privilèges, intégrité



Jeton d'accès

Identité et privilèges de l'utilisateur

Niveau de privilège

Actions et autorisations autorisées

Niveau d'intégrité

Low, Medium, High ou System

Q1

Lire son propre jeton

Quelle commande affiche la liste des **privilèges** portés par le jeton de votre session courante ?

A.

gpresult /r

B.

whoami /priv

C.

net accounts

D.

secedit /export /cfg politique.inf

Q2

L'identifiant qui ne se traduit pas

Le TP n° 1 vous a averti : les noms de groupes sont traduits selon la langue du système. Quel est l'identifiant de sécurité **invariant** du groupe des administrateurs locaux intégrés ?

A.

S-1-5-18

B.

S-1-1-0

C.

S-1-5-32-544

D.

S-1-5-32-545

Q3

Privilège ou permission

SeBackupPrivilege permet de lire un fichier dont la liste de contrôle d'accès refuse explicitement la lecture au porteur.
Comment l'expliquer ?

A.

Le privilège est évalué avant l'ACL et peut la court-circuiter

B.

L'ACL est ignorée pour les membres du groupe Administrateurs

C.

Le privilège modifie temporairement l'ACL du fichier

D.

C'est un comportement non documenté, corrigé depuis Windows 10

Q4

Niveaux d'intégrité

Un utilisateur membre du groupe Administrateurs ouvre une session, puis lance l'explorateur de fichiers **sans élévation**. Quel niveau d'intégrité porte ce processus ?

A.

Low

B.

Medium

C.

High

D.

System

Q5

UAC et accès distant

Quel paramètre, lorsqu'il est activé, redonne un **jeton complet** à un compte local qui se connecte à distance — et rouvre ainsi un chemin de mouvement latéral ?

A.

EnableLUA

B.

FilterAdministratorToken

C.

ConsentPromptBehaviorAdmin

D.

LocalAccountTokenFilterPolicy

Q6

La phrase de Microsoft

Microsoft écrit que l'UAC **n'est pas une frontière de sécurité**. Quelle conséquence pratique en tirer ?

A.

Il faut désactiver l'UAC, qui ne sert à rien

B.

Il faut le régler au maximum, ce qui en fait une frontière

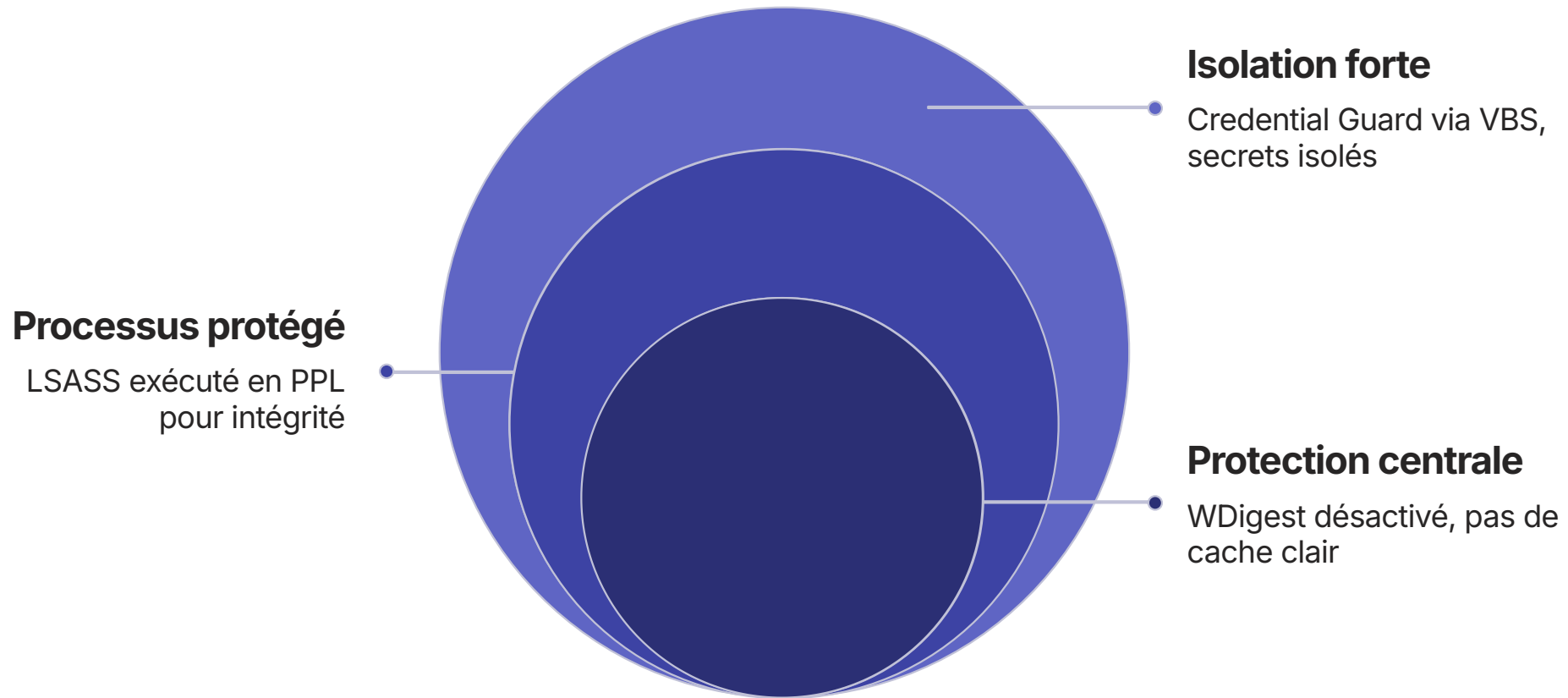
C.

La mesure structurante est la séparation entre compte de travail et compte d'administration

D.

L'UAC ne protège que les comptes standards, pas les administrateurs

Protection des identifiants



Q7

Protéger le processus qui détient les secrets

Quelle valeur de registre active la protection du processus lsass.exe en tant que processus protégé ?

A.

HKLM\SYSTEM\CurrentControlSet\Control\Lsa →
RunAsPPL

B.

HKLM\SOFTWARE\Policies\Microsoft\Windows\System →
ProtectLsass

C.

HKLM\SYSTEM\CurrentControlSet\Services\LSASS →
Protected

D.

HKLM\SOFTWARE\Microsoft\Windows
NT\CurrentVersion\Winlogon → LsaPPL

Q8

Credential Guard

Sur quelle technologie repose l'isolation des secrets d'authentification par Credential Guard ?

A.

Le chiffrement BitLocker du volume système

B.

La sécurité basée sur la virtualisation (VBS)

C.

Le module TPM utilisé seul

D.

Le démarrage sécurisé UEFI

Q9

Le stockage en clair hérité

Quelle valeur neutralise la mise en cache du mot de passe en clair par le fournisseur WDigest ?

A.

UseLogonCredential = 1

B.

UseLogonCredential = 0

C.

Negotiate = 0

D.

DisableWDigest = 1

Q10

Niveau de compatibilité d'authentification

Quelle valeur de `LmCompatibilityLevel` correspond au réglage **le plus strict** — envoyer uniquement NTLMv2, refuser LM et NTLM ?

A.

0

B.

2

C.

3

D.

5

Q11

Ce qui ne prend effet qu'après redémarrage

L'énoncé du TP pratique signalait qu'une des mesures de protection des identifiants **ne s'applique qu'après un redémarrage**, et que le script de vérification passerait quand même avant. Laquelle, et pourquoi le script se laisse-t-il tromper ?

A.

La désactivation de WDigest, parce que le fournisseur est chargé au démarrage

B.

La restriction des accès anonymes, parce qu'elle dépend du service Serveur

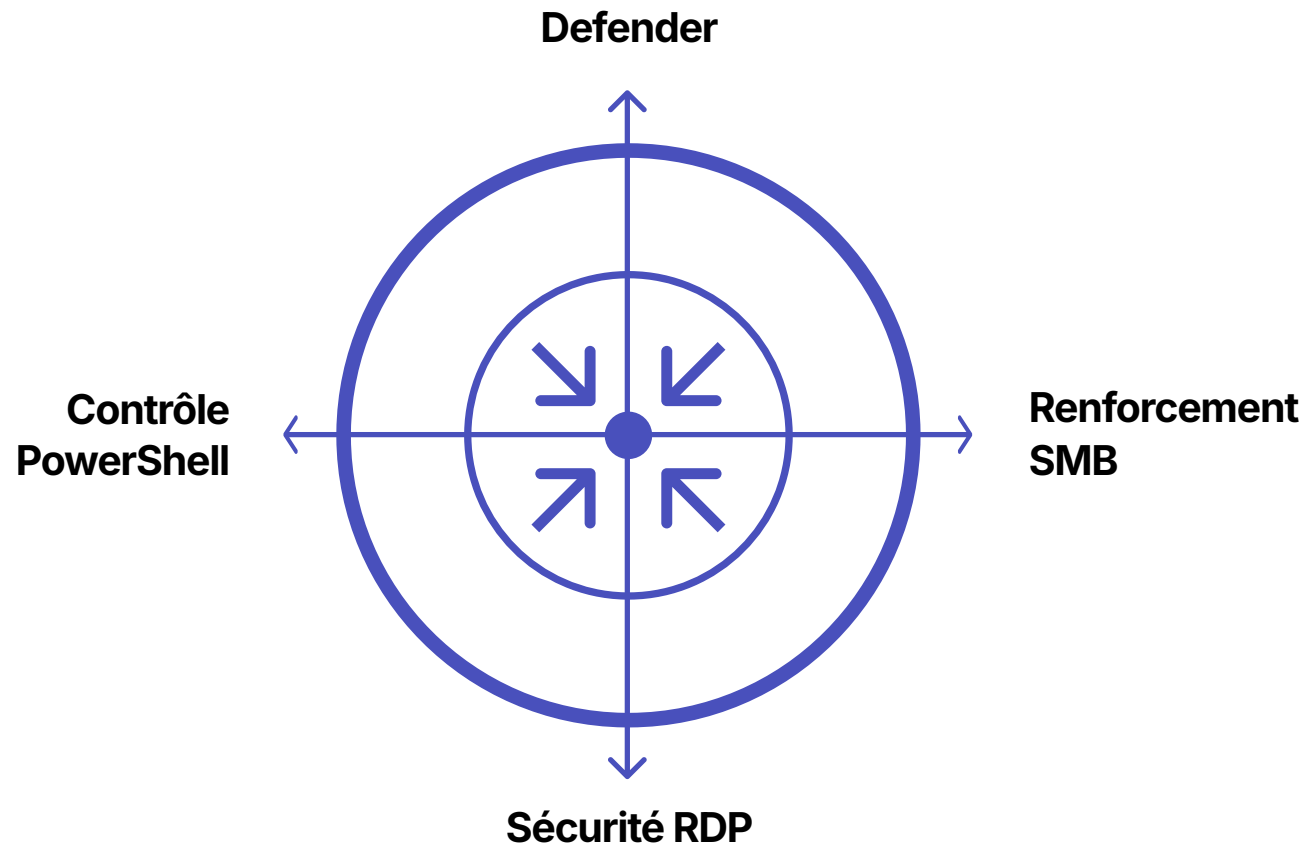
C.

RunAsPPL, parce que la protection est appliquée au lancement de LSASS

D.

LmCompatibilityLevel, parce que la politique est lue à l'ouverture de session

Defender, réseau, exécution



Q12

État de Defender

Quelle applet de commande PowerShell renvoie l'état complet de la protection Microsoft Defender ?

A.

`Get-MpComputerStatus`

B.

`Get-MpPreference`

C.

`Get-DefenderStatus`

D.

`Get-WindowsDefender`

Q13

Règles ASR — observer avant de bloquer

Le sujet insiste : sur un parc réel, on active d'abord les règles de réduction de surface **en mode audit**. Quelle valeur correspond à ce mode ?

A.

0

B.

1

C.

2

D.

6

Q14

Le protocole obsolète

Quelle commande vérifie si le protocole de partage de fichiers de première génération est encore présent sur le système ?

A.

`Get-SmbServerConfiguration`

B.

`Get-WindowsOptionalFeature -Online -FeatureName
SMB1Protocol`

C.

`sc.exe query LanmanServer`

D.

`net share`

Q15

Exiger la signature

Quel paramètre de `Set-SmbServerConfiguration` impose la signature des échanges côté serveur ?

A.

`EnableSecuritySignature`

B.

`RequireSecuritySignature`

C.

`EnableSMB1Protocol`

D.

`RejectUnencryptedAccess`

Q16

Bureau à distance

Le sujet demande, si le bureau à distance est conservé, d'exiger l'authentification au niveau réseau. Quel est l'intérêt **de sécurité** de cette exigence ?

A.

Elle chiffre la session, ce que RDP ne fait pas par défaut

B.

Elle authentifie le client **avant** l'ouverture d'une session graphique, réduisant la surface exposée aux non-authentifiés

C.

Elle limite le nombre de sessions simultanées

D.

Elle impose l'usage d'un compte du domaine

Q17

La politique d'exécution PowerShell

Laquelle de ces affirmations est **exacte** ?

A.

Restricted empêche l'exécution de tout code PowerShell sur la machine

B.

La politique d'exécution est une frontière de sécurité, au même titre qu'AppLocker

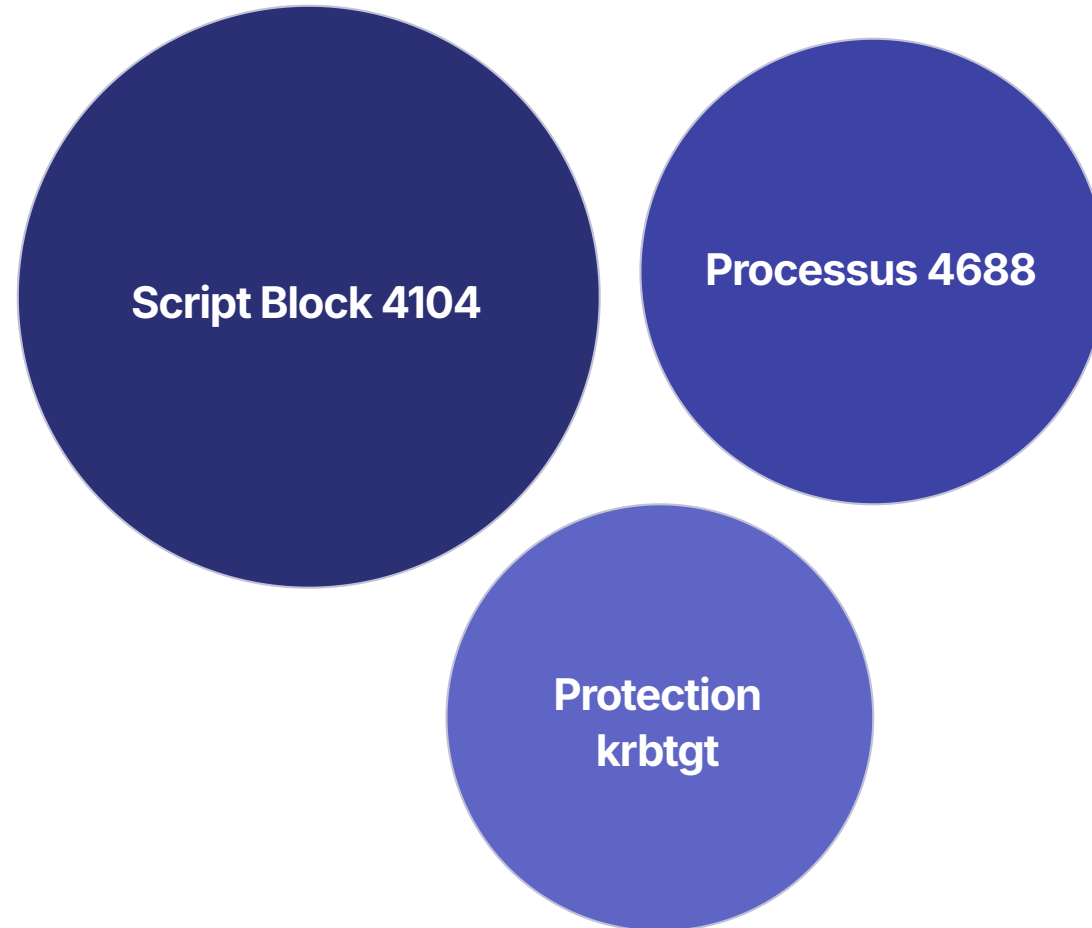
C.

C'est un garde-fou contre l'exécution accidentelle, contournable trivialement ; le vrai contrôle est la liste d'autorisation

D.

AllSigned rend la machine immunisée contre les scripts malveillants

Journalisation et annuaire



Q18

Journaliser ce qui s'exécute

Quel identifiant d'événement correspond à la **journalisation des blocs de script** PowerShell ?

A.

4104

B.

4624

C.

4688

D.

5156

Q19

La ligne de commande

L'événement de création de processus est bien journalisé, mais le champ contenant la ligne de commande est vide. Pourquoi ?

A.

Ce champ n'existe pas sur Windows 11

B.

Il faut activer explicitement l'inclusion de la ligne de commande dans les événements de création de processus

C.

Le journal Sécurité tronque les champs de plus de 260 caractères

D.

Seul Sysmon peut fournir cette information

Q20

Le compte qui détient tout

Dans un domaine Active Directory, quel compte détient la clé qui signe et chiffre les tickets d'octroi de ticket, et dont la compromission rend la reprise du domaine si coûteuse ?

A.

Administrateur

B.

krbtgt

C.

SYSTEM

D.

DC\$

Les quatre questions ouvertes

8 points · une demi-page maximum par question

01

Ouverte 1

Le chemin le plus court — 2 pts

03

Ouverte 3

Transposer, pas recopier — 2 pts

02

Ouverte 2

Trois défenses autour de LSASS — 2 pts

04

Ouverte 4

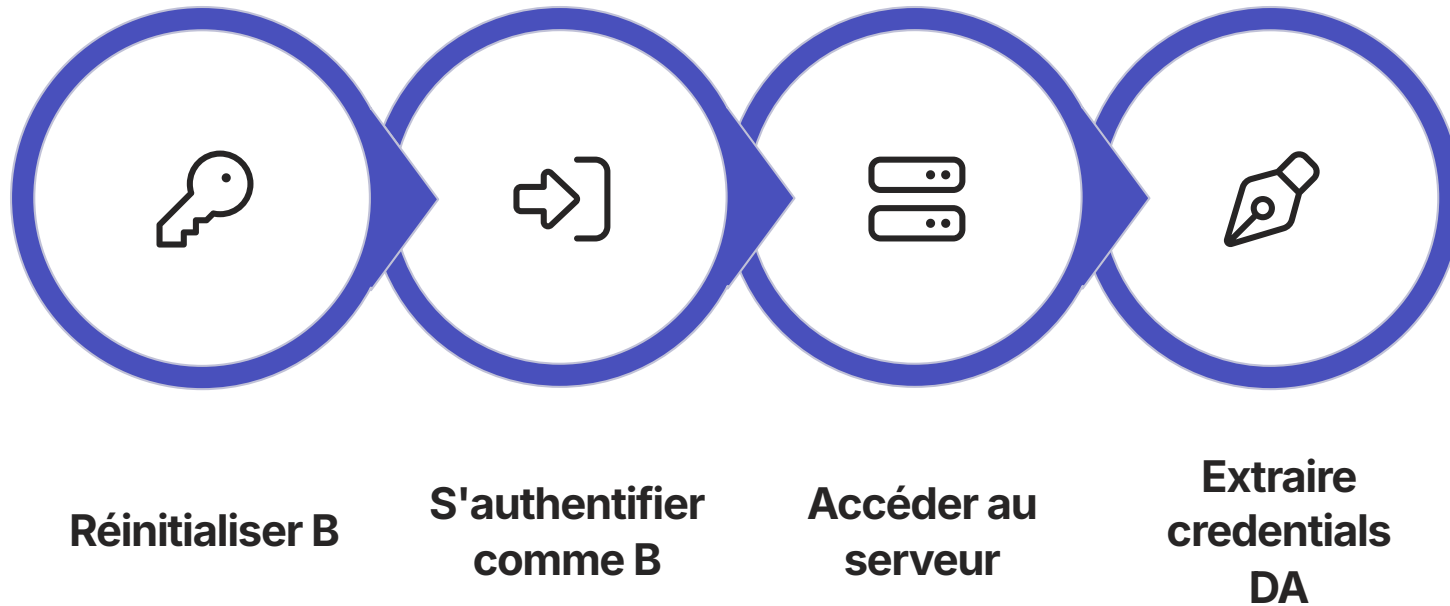
Ce que vous refuseriez — 2 pts

→ OUVERTE 1 · 2 PTS

Le chemin le plus court

Un utilisateur peut réinitialiser le mot de passe d'un second utilisateur. Ce second utilisateur est administrateur local d'un serveur. Un administrateur du domaine a ouvert une session sur ce serveur.

Décrivez le chemin d'attaque complet. Aucune vulnérabilité logicielle n'intervient — dites précisément à quelle étape chaque permission légitime est détournée, et quelle mesure organisationnelle le coupe.



Trois défenses autour de LSASS

RunAsPPL, Credential Guard et le groupe Protected Users protègent le même actif par trois mécanismes différents.

Expliquez ce que chacun retire à l'attaquant, et pourquoi aucun n'est suffisant seul. Donnez un scénario concret où l'un des trois est contourné mais où les deux autres tiennent encore.

RunAsPPL

Protège le processus LSASS contre l'injection de code et la lecture mémoire par des processus non signés.

Credential Guard

Isole les secrets d'authentification dans un environnement virtualisé (VBS), inaccessible même à un processus SYSTEM.

Protected Users

Restreint les protocoles d'authentification utilisables par les membres du groupe, éliminant NTLM et la délégation Kerberos.

↔ OUVERTE 3 · 2 PTS

Transposer, pas recopier

Prenez **trois** mesures que vous avez appliquées sur Debian dans le TP n° 1.

Pour chacune : quel est l'équivalent Windows, en quoi le mécanisme diffère réellement, et y a-t-il un cas où il n'existe pas d'équivalent ? On attend le mécanisme, pas le nom de l'outil.

Mesure Debian	Équivalent Windows	Différence de mécanisme
Mesure 1	À compléter	À analyser
Mesure 2	À compléter	À analyser
Mesure 3	À compléter	À analyser

⊗ OUVERTE 4 · 2 PTS

Ce que vous refuseriez

Vous devez durcir le poste de travail d'un développeur qui compile, exécute des conteneurs et teste du code non signé.

Citez deux mesures de ce module que vous refuseriez d'appliquer sur ce poste, avec l'argument : coût, régression, ou menace non pertinente ici. Puis dites ce que vous mettriez à la place.

Mesure refusée

Identifier deux mesures inadaptées au contexte développeur et argumenter précisément : coût opérationnel, régression fonctionnelle, ou menace non pertinente dans ce contexte.

Mesure de substitution

Proposer une alternative qui maintient un niveau de sécurité acceptable sans bloquer les usages légitimes du développeur.

Le rendu



Format du fichier

Un seul fichier PDF, nommé `NOM-Prenom-TP2.pdf`.



Structure imposée

Les 20 réponses dans l'ordre (lettre, justification, source), puis les 4 questions ouvertes, puis l'annexe de déclaration d'usage d'IA.



Volume

Six pages maximum, annexes non comptées.



Délai

Rendu **en fin de séance** . Malus de 2 points par jour entamé, note nulle au-delà de trois jours.